

Аналитический отчёт · Безопасность · 9 мая 2026

Telegram Forward ID Spoofing

Разбор инцидента в прямом эфире: верификация источника
и анализ эксплойта подделки системных уведомлений.



Ксайнов

Независимый исследователь • первичная фактура и расследование

Telegram • Forward Spoofing • JSON Exploit • Service Notifications • OSINT

9 мая 2026 года в сервисных чатах Telegram, куда приходят коды подтверждения входа — появилось сообщения о смерти Павла Дурова, новости о принудительной интеграции с сервисом “госуслуги” и прямые угрозы расправой. Канал был максимально доверенный для любого пользователя, что создавало ключевую угрозу для простых обывателей платформы.

Все расследование шло в два последовательных этапа.

Этап первый

Верификация аккаунта

Инструменты: *telelog*, *ручной анализ метаданных*

Первым делом нужно было ответить на вопрос, является ли аккаунт вообще официальным? Проверка шла по нескольким независимым критериям.

Номер телефона +33 3 — французский мобильный. Системный чат Telegram привязан к номеру 42777

Список групп через telelog / funstat — аккаунт состоит в десятках обычных чатов: “шарашкина контора”, “кормушка”, крипто-болталки. Системная сущность мессенджера по своему техническому бэкграунду не должна вступать в подобные группы.

Раздел с подарками (18 gifts) — у настоящего системного чата нет раздела с подарками. Сама возможность их дарить отсутствует.

Несовпадение идентификаторов — у официального аккаунта который предназначен для системных уведомлений уникальный и неизменный идентификатор: 777000. Аккаунт для псевдо-системных уведомлений в свою очередь имеет UID: 333000.

Вывод этапа 1: аккаунт **НЕ ОФИЦИАЛЬНЫЙ** и не имеет отношения к системе Telegram.

Этап второй

Разбор схемы: как это работало и стоило ли верить

Технический анализ + оценка угрозы.

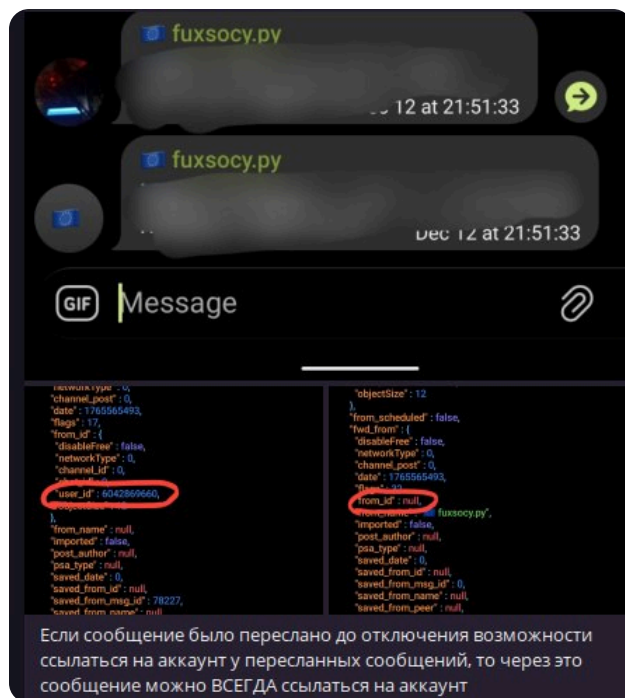
Верификация показала: аккаунт — не официальный. Но тогда встал следующий вопрос: как именно неофициальный аккаунт попал в доверенную ветку системных уведомлений? И почему вообще кто-то мог поверить?

[Ответ дал sudosudo](#), [подтвердил Ретрокат](#):

“Telegram определяет, показывать ли ссылку на аккаунт в пересланном сообщении, на основании одного параметра.

Уязвимость: ссылка на аккаунт в forwarded message зависит от того, прописан ли user_id в JSON самого сообщения — а не от того, включена ли возможность ссылки у пользователя прямо сейчас.

Вывод: подставив ID псевдо-системного аккаунта (333000), сообщение отображалось как официальное уведомление. Настройки приватности жертвы роли не играли.”



Это означает, что **любой аккаунт** мог сформировать сообщение, которое клиент воспринимал как системное, с учетом попадания в доверенную ветку и визуальными признаками официальности. Уязвимость, по всей видимости, существовала годами.

Стоило ли верить сообщениям? По совокупности всех факторов — нет:

Содержания сообщений в основном были мусорным спамом основанным на современных мемах.

Официальный канал @durov — молчит, хотя новости о его смерти опубликовались бы одновременно с рассылкой.

Итоговое подтверждение от других энтузиастов показало, что это лишь эксплоит.

Вывод этапа 2: **Эксплоит** — верить не стоило, но угроза была реальной.

Оценка угрозы

Нереализованный потенциал — критическая уязвимость

Эксплоит позволял подделать сообщение от любого аккаунта в Telegram. В данном случае

его использовали для троллинга и вброса о смерти Дурова. Но та же механика позволяла провести масштабную фишинговую атаку — достаточно попросить “подтвердить аккаунт” от имени системного чата., или обрушить курс TON. Единственное, что спасло: исполнители оказались непрофессиональными хулиганами.

Благодарности. Спасибо всем, кто стихийно оказался рядом в этом расследовании:

Петрокату — за подтверждение факта эксплойта и информацию о фиксе; **sudosudo** — за точную техническую формулировку механики уязвимости; участникам чатов, чьи реакции помогли выстроить таймлайн.